

VI.B.5 Scheduling

In IT, job scheduling is the planning and managing of the execution of software tasks that are required as part of an IT service. IT operations management is responsible for scheduling, which is often automated using software tools that run batch or online tasks at specific times of the day, week, month, or year. Scheduling allows management to allocate resources to limit downtime and ensure adequate use of servers and processing equipment. Management should implement policies, standards, and procedures for creating and changing job schedules and analyzing and maximizing the entity's resources. Automated scheduling tools can help improve management's ability to analyze and maximize scheduling efficiency. In addition to routine scheduling, these tools may be used to assign priorities and allocate computer resources to non-routine processing.

VI.B.6 Capacity Management

Capacity management is the process of planning and monitoring an entity's technology resources to support current and future strategic objectives. It involves the use of baseline performance data to model and project an entity's future needs. Capacity management should be closely integrated with the budgeting and strategic planning processes. Management should implement capacity management processes that address internal factors (e.g., growth, mergers, acquisitions, new product lines, and implementation of new technologies) and external factors (e.g., shift in customer preferences, competitor capability, and market requirements).

Capacity management activities can be supported by automated tools to allow management to more easily analyze the information it receives. Management should routinely assess capacity against baselines to ensure adequate performance in the following:

- Platform processing speed.
- Primary working memory⁸⁰ for each platform's central processing unit (CPU).
- Additional data storage capacity.
- Voice and data communication bandwidth.

Management should analyze capacity trends to ensure that capacity continues to meet entity needs. When appropriate, management should analyze help desk records to determine whether incidents were caused by capacity issues. Management should periodically analyze projected versus actual capacity to determine whether capacity planning processes are appropriate or should be adjusted.

As part of its planning processes, management should consider testing applications and systems to verify that they will meet the entity's demands during periods of high volume. Periodically, IT management should meet with business line management to determine whether future projects may affect the entity's capacity needs. When building or acquiring new technology, management should consider flexibility to accommodate the entity's future capacity requirements. As a part of

⁸⁰ For the purposes of this booklet, primary working memory refers to the temporary storage or memory needed to run software applications that is shipped with the CPU and is generally supplemented by additional data storage (i.e., long-term storage).

sound capacity planning, management should evaluate third-party service providers' performance in combination with internal performance to help determine whether existing demands are being met and future demands can be achieved.

VI.B.7 Log Management

Log management is the process to generate, transmit, store, analyze, and dispose of log data. With respect to operations, a log is a record of events occurring within an entity's systems and networks. Management should have a process to use logs to identify, track, analyze, and resolve problems that occur during day-to-day operations. Logs may record activity performed on the entity's systems and software (e.g., OS, software application, network device, or security system). The entity may use specifically designed monitoring software or devices to capture logs. Logs are often used to track user access, system messages, and device performance and capacity. Examples of logs include:

- Occurrence (e.g., successful backups, last malware scanned, signature updates, patch installation, and system events).
- Anomaly (e.g., failed backups, failed log-on attempts, and suspicious activity).
- Usage (e.g., capacity).
- Activity (e.g., intrusion detection and protection actions taken, authentication success and failure, and blocked traffic).

Analyzing logs allows management to troubleshoot problems, investigate malicious activity, understand the entity's baseline activities, and support improvement activities. A challenge of log management is balancing the amount of data collected, the storage and capacity available, the ability to analyze the data, and the capability to respond to issues raised through that analysis. At times, the amount of data collected can make it difficult to identify anomalies. Another issue management should address is identifying and dispositioning false positives. Once false positives are identified, management should adjust logging parameters to minimize the volume of false positives in future log reviews. Log management is a shared responsibility among an entity's operations and information security personnel. Management should implement policies, standards, and procedures for log management activities that address the following:

- Objectives for logging.
- Types of logs to be collected.
- Controls to restrict access to log settings.
- Response time for log review (e.g., real-time).
- Retention time frames and storage policies of logs.
- Escalation processes for anomalies.

Management should configure logging to match the entity's risk and complexity and identify and address anomalies. Because logs can be large and difficult to analyze by humans, management should consider using tools to automate log analysis and extract important events or patterns. Automated tools can help identify anomalies and automatically alert management to potential issues or events. Management should implement controls to protect logs to preserve their

integrity and prevent log information from being misused. Refer to the *IT Handbook's* "[Information Security](#)" booklet for more information.

VI.B.8 Disposal of Data and Media

Management should implement policies, standards, and procedures to address media⁸¹ and equipment disposal or transfer. Disposal processes are a shared responsibility among several of an entity's functions, including operations, information security, and third-party service provider management. Controls involved in the disposal process should be risk-based relative to the sensitivity of the information as defined by the entity's data classification⁸² policy and the type of media used. The procedures should define methods for disposal based on the type of data to be removed. For example, management may choose to physically destroy media that contain customer sensitive information to prevent data recovery and misuse. Management should consider using techniques to remove data even when transferring the media between internal departments, as not all internal departments require access to sensitive or confidential information. For example, often media is reused after an employee leaves the entity; if someone in a customer-facing function with access to sensitive customer information leaves the entity, the information should be removed from the laptop before issuing it to other employees. Management should have appropriate procedures for the disposal of equipment (e.g., printers), which may contain residual data. Periodically, management should perform a review to ensure the timely disposal of decommissioned equipment.

The disposal of records stored on electronic media presents unique challenges because residual data can remain on the media after erasure. As technology evolves, techniques previously used may no longer be effective. For example, degaussing was an effective tool to remove data stored on magnetic media, but degaussing is not effective for non-magnetic media, such as flash drives. Even magnetic media has evolved to a point that additional techniques beyond degaussing should be considered. Because data can be recovered, additional disposal techniques (e.g., data destruction) should be applied to remove sensitive information. Refer to the *IT Handbook's* "[Information Security](#)" booklet for more information.

⁸¹ In the context of this booklet, media includes physical media (e.g., paper), electronic media (e.g., hard drives, disks, and removable drives), and virtualized copies.

⁸² For example, the Information Security Standards direct each financial institution to develop, implement, and maintain, as part of its information security program, appropriate measures to properly dispose of "customer information" and "consumer information." Refer to 12 CFR 30, appendix B (OCC); 12 CFR 208, appendix D-2 and 225, appendix F (FRB); 12 CFR 364, appendix B (FDIC); and 12 CFR 748, appendix A (NCUA).

VI.C Service and Support Processes

Action Summary

Management should develop and implement service and support processes. These processes should be designed to support an entity's strategic goals and objectives by preventing issues, ensuring continuous reliability and resilience, and supporting users (e.g., business lines, personnel, and customers).

Examiners should review for the following:

- Effective planning processes for service management that consider services offered, SLAs and contractual provisions, known limitations, and metrics and measurements.
- Communication processes with business line management.
- Operational support processes, controls, and mechanisms to report transmission and processing errors.
- Processes to document and track issues through resolution.
- Documented event, incident, and problem management processes.

VI.C.1 Service Management

Service management is the process of overseeing and managing an entity's activities and resources to allow management of IT functions to support and service the entity's strategic goals and objectives. The success of service management is normally gauged by the overall quality of service and proactive identification and resolution of problems. Service management functions should be designed with an emphasis on preventing issues and ensuring continuous reliability and resilience where possible. As part of its planning, management should consider the following:

- Services offered and SLAs, operational level agreements (OLAs), or contractual provisions.
- Activities performed by third-party service providers.
- Known limitations that may affect service management functions and activities (e.g., capacity issues or resource constraints).
- Applicable legal and regulatory requirements.
- Resources (e.g., human, technical, equipment, and capacity) necessary to carry out service management functions and activities.
- Metrics and measurements used to evaluate service management effectiveness.

The service management function ensures that business functions have technology available to support business objectives and end users have the resources to perform their jobs efficiently and effectively. Many entities develop service catalogs to outline the services and functions offered. The catalogs often describe the services and dependencies between services or functions.

SLAs, referred to as OLAs when used for internal service delivery, often outline business line expectations for service management and support functions (e.g., uptime requirements and response times). Documented OLAs are less common in smaller or less complex entities; business line management, however, should still communicate and coordinate its business requirements to personnel responsible for the execution of service management functions. OLAs and requirements may act as a baseline for any SLAs with third-party service providers. When an entity uses third-party service providers, management should coordinate its processes with them to ensure seamless functionality to the entity's lines of business.

As technology continues to evolve, more entities are aligning IT with business processes to simplify IT activities and to increase business line satisfaction. For example, several entities have implemented staff self-service processes to handle support tasks, such as hardware or software requests or password resets.

Periodically, the process owners from both business and technology functions should meet to discuss known issues, changes in progress, and future changes. These meetings help ensure that service management continues to support operations and the lines of business.

VI.C.2 Operational Support

Operational support personnel perform activities that either directly or indirectly support the entity's lines of business. Management in the lines of business may not have insight into the activities performed by operational personnel or into supporting systems or software. Management should implement the following:

- Processes to verify that incoming data transmissions and processing are complete and accurate.
- Controls to verify that external data transmissions and processing are securely received in accordance with entity policies, procedures, and standards.
- Controls to verify that data were not corrupted during transmission or as a result of processing failures.
- Mechanisms to report transmission and processing errors.

Operational support personnel should report any errors or problems with the systems or software to management in the lines of business and provide frequent updates on the resolution of issues.

VI.C.3 IT Support

IT support provides the entity's personnel and clients with technical assistance; troubleshooting advice regarding software, hardware, or networks; and assistance with events, incidents, or problems. In some entities, this function may be referred to as client support, help desk, or service desk. IT support may consist of dedicated staff trained in problem resolution, equipped with issue tracking software, and supported with knowledge-based systems that serve as a resource for common problems. In smaller or less complex entities, IT support may consist of a single person or a small staff or provided through a contract with a third-party service provider.

Larger or more complex entities often use documented service requests within a system to track their activities and the actions taken. Smaller or less complex entities often track and fulfill business requests through less formal processes. A tracking system helps management prioritize issues, track problems through resolution, and analyze the problem database for systemic concerns. A tracking system can be used to monitor IT support performance. Some tracking systems allow users to monitor problem resolution. Known issues and related fixes or resolutions should be documented in the system.

IT support should record and track incoming issues, whether handled by human operators or automated systems. Tracking requests creates a historical record and allows management to perform trend analysis. The tracking system documentation should include the following:

- User name and contact information.
- Problem description.
- Request type and category.
- Affected system (e.g., hardware, software, or other device).
- Prioritization code.
- Current status toward resolution.
- Individual or group responsible for resolution.
- Root cause, when identified.
- Target resolution time frame.
- Comments related to user interaction (e.g., number of calls for resolution) with IT support and any other pertinent information (e.g., resolution attempts).

Management should maintain well-trained and knowledgeable IT support personnel to effectively support clients and users. If IT support software is used, IT support personnel should have appropriate training to perform their duties. IT support should follow procedures to authenticate users to prevent unauthorized access to information or credentials. The entity may choose to use different levels of authentication depending on the method of contact (e.g., telephone, website, or chat), the problem reported, the type of action requested, or the platform, system, or data involved. Management should consider layered security and supplemental authentication techniques,⁸³ including out-of-band methods for changes to account maintenance activities (e.g., address or password changes) and for those involving high-risk transactions⁸⁴ to limit attempted fraud through social engineering or identify theft. Refer to the *IT Handbook's* "[Information Security](#)" booklet for more information.

If the IT support function is outsourced, management should include management's IT support expectations and responsibilities for the third-party service provider in the contract. Responsibilities may include information access level, functions it will perform, controls for security and confidentiality, and reporting and metrics to be provided. Refer to the *IT Handbook's* "[Outsourcing Technology Services](#)" booklet for more information.

⁸³ Techniques include multifactor authentication, pre-established personal identification numbers (PIN) or passphrases, and call-backs at established numbers.

⁸⁴ Refer to the FFIEC's [Supplement to Authentication in an Internet Banking Environment](#).

VI.C.4 Event, Incident, and Problem Management

Entities face a variety of events, incidents, and problems throughout the normal course of business. Managing these situations is important to minimizing disruptions on the entity's daily operations and its ability to service customers. Therefore, management of these situations is a shared responsibility among several of an entity's functions, including operations, information security, business continuity management, and third-party service provider management. Entity management may define and execute event, incident, and problem management processes differently throughout the entity (e.g., within the IT environment, at the business unit level, or at the enterprise level). To minimize confusion, management should implement processes to coordinate and define roles and responsibilities and conduct testing to identify interdependencies.

Event management is the process used to track issues that occur in the IT infrastructure and detect and escalate those issues. Incident management is the process of identifying, analyzing, and correcting disruptions to operations and preventing future recurrences. The goal of incident management is to limit the disruption and restore operations as quickly as possible. Problem management is the process employed to manage the life cycle of an entity's problems. Its goal is to proactively prevent problems from becoming incidents and lessen the impact of incidents that management cannot prevent.

Management should implement processes to plan for and manage events, incidents, and problems. Management should establish and maintain appropriate processes and controls to help protect the entity from financial, operational, reputation, and other risks. These processes should include the following:

- Identifying the event, incident, or problem.
- Determining the impact (e.g., number of customers and employees affected, revenue lost, expenses incurred, SLAs or OLAs breached, and reputation damaged).
- Assigning a severity rating based on risk (e.g., breach of confidentiality, integrity, or availability of customer or entity data).
- Performing root cause analysis to prevent repeat incidents.
- Identifying, logging, tracking, and analyzing events, incidents, and problems that occur during day-to-day operations.
- Maintaining contact information for individuals and groups (e.g., regulators, law enforcement, internal public relations, and affected lines of business) who should be notified and the circumstances under which they should be notified.
- Informing the help desk of the event, incident, or problem and how to respond (e.g., using a script to provide information on the situation).
- Resolving the event, incident, or problem, including approval processes for system or software changes to correct the issue.
- Documenting any interim actions, compensating controls, and, if necessary, risk acceptance for issues that cannot be immediately resolved.
- Developing longer-term action plans to monitor and address issues that cannot be resolved in a timely manner.
- Reporting on the progress of the action plans to senior management.

- Implementing procedures for escalation and reporting to management and stakeholders.
- Implementing procedures to correlate events to determine whether there are underlying issues preventing resolution and allowing events to recur.

Management should consider performing periodic trend analysis to determine whether there are recurring or related issues that may be tracked to a common root cause. This would allow management to maintain systems and software and make timely changes to prevent future issues. The analysis also helps management support continuous improvement processes (refer to the [“Continuous Improvement”](#) section of this booklet for more information).

Event, incident, and problem management plans should cover hardware, software, and security devices. Situations may include issues related to confidentiality (e.g., security breaches), integrity (e.g., out-of-balance conditions or logging issues), and availability (e.g., production program failures or database corruption). Processes to manage these and other situations should be communicated and readily available to appropriate personnel.⁸⁵ Processes should be coordinated and included within the entity’s incident response program, as discussed in the *IT Handbook’s* [“Information Security”](#) and [“Business Continuity Management”](#) booklets.

VI.D Ongoing Monitoring and Evaluation Processes

Action Summary

Management should develop processes to oversee operations functions, evaluate the effectiveness of controls, and identify opportunities for improvement.

Examiners should review for the following:

- Implementation of processes to monitor and report on control effectiveness.
- Stakeholder input into the types of reports and metrics produced.
- Defined objectives for IT, operations, and key performance indicators (KPI).
- KPIs that align with the entity’s ERM processes.
- Processes for reporting KPIs to the board.
- Implementation of corrective action plans when KPIs do not meet established targets.
- Processes to recommend changes in operations processes and controls.
- Strategies for service and process improvement and methods to measure the results of those improvement efforts.

⁸⁵ Appropriate personnel include IT operations personnel, entity management, internal audit, fraud and loss prevention department, information security, computer security incident response teams, and personnel from third-party service providers.

VI.D.1 Monitoring and Reporting

Management should implement processes to monitor IT operations and periodically report on the effectiveness of established controls to senior management and other stakeholders. They should have input into the types of reports and metrics produced and reports should be understandable and useful to them. Regular monitoring can help management identify risk within operations (e.g., ineffective controls, inefficient processes, insufficient or inefficient use of resources, and substandard service delivery). The operations team should report performance metrics to senior management and other stakeholders. Operations management should meet periodically with senior management and other stakeholders to assess the value of the monitoring and reporting and to identify any changes (e.g., stakeholders, requirements, objectives, and metrics).

Monitoring and reporting support proactive systems management activities to position the entity to meet its current needs and plan for periods of growth, mergers, or expansion of product lines. Examples of IT operations reports include the following:

- Hardware and data communications capacity utilization.
- System information (e.g., system availability, system response times, and on-time processing).
- Transaction processing completeness and accuracy.
- Security-related information, such as vulnerability management metrics.
- Service-level benchmarks compared to actual service performance.
- KPIs, discussed further in the next section.

Management should monitor third-party service providers as part of the entity's third-party risk management program. Reports from third-party service providers should include effectiveness of security controls, performance metrics, resolved versus outstanding issues, and root causes of problems. Management should monitor the third-party service provider's ability to meet defined SLAs, compliance with identified action plans when they are not met, and remuneration of penalty fees when appropriate.

Entities that have migrated to a cloud computing environment may find that traditional operations monitoring and reporting tools and techniques are no longer effective. For example, encryption or containers may impede the operation and accuracy of some tools. Management should explore the use of tools designed for cloud computing, either by the cloud service provider or external vendors. Some examples of these tools include cloud service provider-offered monitoring services and third-party applications (such as CASBs or agent-based monitoring).

VI.D.2 IT and Operations Key Performance Indicators

KPIs are measures that determine how well the process is performing in enabling the goal to be reached. Management should define objectives for IT and operations and KPIs to help management measure those objectives. KPIs should align with the entity's ERM processes and allow management to assess the performance of IT and operations across the entity.

Management should set KPI benchmarks it wants to achieve and analyze deviations from those benchmarks. The collection of KPIs should be automated to the extent possible. Examples of IT and operations KPIs may include the following:

- Resource utilization by application or time of day.
- Network availability (e.g., uptime).
- Response time, access types by service, or average connect time.
- Voice response unit call capacity.
- Mobile and internet banking capacity.
- System failures.
- Help desk performance metrics (e.g., number of calls answered, average talk and wait times, total ticket duration, mean time to resolve, and percent of first contact resolution).
- Virtualization metrics (e.g., memory availability and network bandwidth).
- Change management metrics (e.g., total number of changes and number of emergency or unplanned changes).

Information gained from analysis supports daily management of operations and early alerting of potential operational issues. As part of the entity's monitoring and review processes, management should regularly review KPI reports and provide appropriate reporting up to the board, if necessary. Management should implement corrective action plans to address the deviations or negative trends, assign individuals responsible, and monitor progress to completion. Periodically, management should meet with stakeholders to review the IT and operations KPIs. Management should determine whether the KPIs are appropriate indicators to demonstrate the ability to meet the entity's strategic objectives.

In conjunction with KPIs, a common method of measuring operational risk is through the use of key risk indicators (KRI). KRIs are a subset of risk indicators that are highly relevant and possess a high probability of predicting or indicating important risk. Refer to the *IT Handbook's* "[Management](#)" booklet for more information on KRIs.

VI.D.3 Control Self-Assessments

A control self-assessment, sometimes referred to as a risk control self-assessment, is a technique that allows managers and work teams directly involved in business units, functions, or processes to participate in assessing the entity's risk management and control processes. Management can use these assessments to monitor the effectiveness of IT operations controls as well as to gauge performance, assess the criticality of systems, and identify existing risks. Control self-assessments do not eliminate the need for independent audits. The results should be evaluated by management and used to continuously improve the entity's operations.

VI.D.4 Continuous Improvement

Continuous improvement is the ongoing effort to improve an entity's products, services, or processes to meet business objectives. An entity's reliance on technology involves continuous innovation and the need for updated and more advanced systems. Improvement efforts in